

R17

HTB · STARTING POINT

HTB Starting Point — Redeemer

Programación para Ciberseguridad · Fase II · AD2026

Redis es una base de datos en memoria muy usada para caché y colas de mensajes. Sin autenticación, un servidor Redis expuesto a la red permite a cualquiera leer y escribir todos los datos almacenados — incluyendo tokens de sesión, cachés de contraseñas y configuraciones sensibles.

Objetivo: Conectarse a un servidor Redis sin autenticación, enumerar su contenido desde la terminal y recuperar la flag.

Acceso a la plataforma

Ve a Starting Point → Tier 0 → Redeemer e inicia la máquina.

Pistas de enfoque

Escanea con `nmap -p 6379`. Conéctate con `redis-cli -h <IP>`. Dentro del cliente Redis, usa `INFO`, `KEYS *` y `GET <clave>` para explorar el contenido y encontrar la flag.

Evidencias requeridas

- Screenshot del escaneo de `nmap`.
- Screenshot de la sesión `redis-cli` con la flag recuperada.

Preguntas de reflexión

1. Redis está diseñado para ser rápido, no para ser seguro por defecto. ¿Qué configuración mínima debería tener un servidor Redis para no ser explotable como el de esta máquina?
2. Los datos en Redis son efímeros (desaparecen al reiniciar el servidor). ¿Qué tipo de dato sensible sería el más valioso para un atacante en un servidor Redis de producción real?
3. `KEYS *` devuelve todas las claves de la base de datos. ¿Por qué ese comando estaría deshabilitado en un servidor Redis de producción bien configurado?